

Access Review Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 CC6.3 (Manages logical access modifications) · HIPAA §164.308(a)(4)(ii)(C) periodic review · ISO 27001 A.5.18 (Access rights review) **Companion documents:** Access Control Policy (§6 — the systems inventory this reviews) · Vendor Management Policy (§3 — the vendor consoles each review covers) · Risk Management Policy (R-13 — Sami-unavailable risk).

1. Purpose

Turn "who has admin on what" from a memory item into a scheduled artifact. The review IS the compliance object — a periodic, dated, signed record that access is currently what we intend it to be, not what it accumulated to.

2. Scope

Every system listed in Access Control Policy §6 plus every vendor listed in Vendor Management Policy §3. Reviews are per-system with a fixed cadence and a documented procedure — not a monthly meeting where we forget half the systems.

3. Review cadence

Frequency scaled by blast radius of unauthorized access.

System	Cadence	Rationale
Issuer signing seed access (1Password entry + paper backup + Render env var)	Quarterly	Root of paid-tier trust. Any additional holder = potential leak surface.
Render team members + role	Quarterly	Render admin = production env vars = every secret we hold.
Stripe team members + role	Quarterly	Stripe admin = payments + subscription mutation authority.
VPS <code>157.230.177.45</code> SSH keys (<code>~/.ssh/authorized_keys</code> for <code>sami</code> and <code>root</code>)	Quarterly	Any SSH key here = installer/tarball mirror mutation authority.
GitHub org (patl4588) owners + admins + repo write	Quarterly	Any org owner = push to <code>main</code> = deploy authority.
1Password shared vault members	Annually	Vault is E2E encrypted; unauthorized addition is bounded (they'd still need master passphrase to read).
Cloudflare DNS admin	Annually	Lower blast (DNS change is visible externally quickly).
Anthropic API key holders (Probo dev key + any prod key)	Annually	Cost surface, not customer-data surface.
DigitalOcean team + billing admin	Annually	VPS lives here; SSH review above catches the more urgent surface.

Reviews happen in the FIRST calendar month of the quarter (Jan/Apr/Jul/Oct) unless a review-trigger event fires first (§5).

4. Review procedure

For each system, the review is a 5-step checklist. Written so it can be done in one sitting; typical duration 15–30 min per system for the quarterly ones.

- List every current holder + role.** From the system's own admin console (Render team page, Stripe team page, `cat ~/.ssh/authorized_keys` on the VPS, GitHub org people page).
- Compare against intended holders** (Access Control Policy §6, Vendor Management Policy §3). Any mismatch = finding.
- Justify every holder still needed.** For each name: one sentence — why do they still need this access? "Sami is the Security Officer" is a valid justification. "I don't remember why we added them" is a finding.

4. **Revoke anything not justified.** Same session — don't defer. If revocation is politically awkward (a former contractor), do it anyway and communicate after.
5. **Log the review.** Timestamped entry with per-holder decisions. See §6 for template.

5. Review-trigger events (out-of-cycle reviews)

The scheduled cadence catches drift. These events trigger an immediate review of the affected system, regardless of scheduled date:

- **Any incident of SEV-2 or higher touching that system's credentials** — per Incident Response Policy §7.5, §7.6.
- **Person leaves the team.** Every access they had is revoked before they walk out the door (or, in a fully-remote team, before the day ends).
- **Person's role changes.** Access is re-scoped to the new role, old access removed the same day.
- **Vendor pricing/policy change** that alters who NEEDS access (e.g., Render team-size upgrade).
- **New root-tier secret added** (e.g., issuer key rotation is a trigger for the "issuer signing seed access" review).
- **Any admin console shows a login by a name we don't recognize** — treat as SEV-1 until proven otherwise, review is one of the response actions.

6. Review log template

Kept as append-only markdown in `~/access-reviews/YYYY-QN-<system>.md` on Sami's box. Each review is one file; the file IS the artifact HIPAA + SOC 2 examiners ask to see.

```
# Access Review – <system> – YYYY QN
```

```
**Date:** YYYY-MM-DD
```

```
**Reviewer:** <name, role>
```

```
**Cadence trigger:** scheduled Q1 2026 / triggered by <event>
```

```
## Holders + decisions
```

```
| Name | Role | Access since | Still needed? | Decision | Rationale |
|---|---|---|---|---|---|
| Sami Ben Chaalia | admin | 2025-XX | yes | keep | Security Officer per Access Cont
| Pat Linden | owner | 2025-XX | yes | keep | Business owner; operational continuity
| (example) John X | contributor | 2026-05 | no | REVOKE | Contract ended 2026-06; a
```

```
## Findings
```

- Any holder not intended per policy: describe + action taken.
- Any policy update needed: describe + link to updated Probo entry.

```
## Sign-off
```

```
Reviewer: _____ Date: _____
```

Every review file gets a companion Probo entry via `addEvidence` (or attached to the corresponding control in the SOC 2 framework) so the compliance program can trace back to the actual review artifact.

7. Findings + remediation

Any finding from §4 step 4 or §5 that isn't remediated during the review session becomes a tracked item:

- Logged as a risk in Risk Management Policy §6 (usually LOW score unless the finding indicates active compromise).
- Owner assigned; target-date within 5 business days for a MEDIUM+ finding, next review for LOW.
- Reviewed at the following quarter's review for that system.

8. Emergency revocation

Any credential holder can revoke ANOTHER holder's access without waiting for a review if there's reasonable suspicion of compromise or misuse. Log the revocation as a SEV-2 incident and initiate a

review the same day. The cost of a bad revocation (short-lived lockout, easily restored) is far less than the cost of unauthorized action.

9. Automation

Where feasible, the "list holders" step (§4 step 1) is automated:

- **VPS SSH keys:** `ssh sami@157.230.177.45 'cat ~/.ssh/authorized_keys /root/.ssh/authorized_keys'` — trivially scriptable, no admin console click needed.
- **GitHub org members:** `gh api orgs/patl4588/members` returns the list; `gh api orgs/patl4588/teams/<team>/members` for role-scoped views.
- **Render team:** requires the Render dashboard (no public API for team members at time of writing).
- **Stripe team:** dashboard-only currently.

The scripts for the automatable ones live in `railcall-core/tools/access-review/` (TO BE CREATED). Automation is an accelerator, not a substitute for the human review — the "still needed?" judgement is not scriptable.

10. Review

This policy itself is reviewed annually + any time the review cadence in §3 changes. Cadence tightening (e.g., moving from quarterly to monthly for a specific system) triggers an immediate one-time review of that system to establish a new baseline.

11. Related documents

- **Access Control Policy §6** — the systems inventory that §3 mirrors.
- **Vendor Management Policy §3** — the vendor console list §3 also covers.
- **Risk Management Policy §6 R-13** — the "Sami unavailable" risk this policy partially mitigates by ensuring Pat's continued VPS/Render access.
- **Incident Response Policy §7.5–7.6** — the credential compromise runbooks that trigger §5 out-of-cycle reviews.